Incident Report

Unauthorized Samba Exploitation Attempt – Metasploitable2 Host

Executive Summary

On **18 August 2025 at approximately 14:00**, the Security Operations Center (SOC) detected a suspicious exploitation attempt targeting the **Samba service** running on the internal Linux server **172.23.134.132**. The attack originated from an external attacker-controlled machine using a known Samba vulnerability associated with **MITRE ATT&CK Technique T1210 (Exploitation of Remote Services)**.

The malicious activity was successfully identified through **Wazuh monitoring alerts**, indicating unauthorized remote command execution behavior. Immediate containment actions were performed by isolating the affected host and blocking the attacker's IP address using firewall controls. Initial investigation confirmed exploit execution but found no evidence of persistence mechanisms or lateral movement attempts.

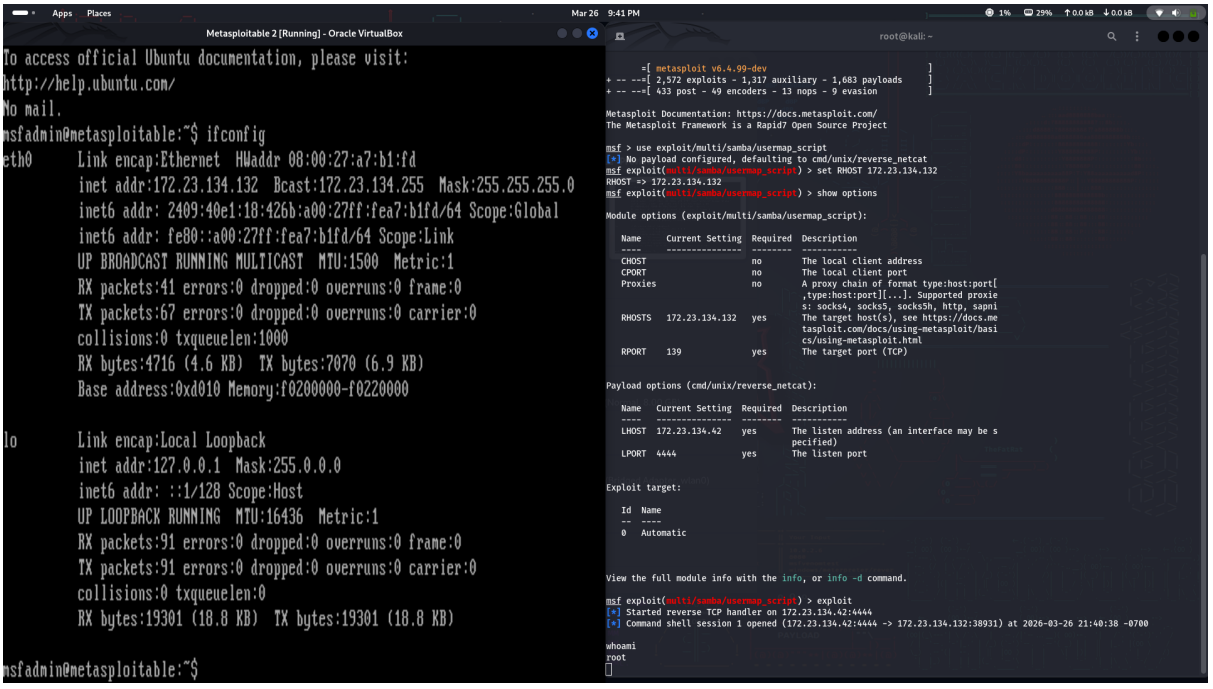
The incident was escalated to **Tier 2 analysts** for deeper forensic validation and verification of system integrity. Preventive security recommendations include patch management improvements and restricting exposure of vulnerable services.

Incident Timeline

Time	Event Description
14:00	Samba exploitation attempt initiated from attacker system
14:01	Wazuh generated security alert indicating suspicious activity
14:03	SOC analyst validated exploit indicators in security logs
14:05	Investigation confirmed unauthorized remote command execution
14:08	Attacker IP blocked using firewall containment controls

14:10 Connectivity between attacker and victim host terminated

14:12 Incident escalated to Tier 2 investigation team



Technical Analysis

During routine security monitoring operations, **Wazuh SIEM** generated an alert indicating suspicious activity targeting the Samba service running on host **172.23.134.132**. Log correlation confirmed that the attacker attempted to exploit a known vulnerability using the **Metasploit Samba usermap_script module**.

The exploit enabled unauthorized remote shell access to the target system, demonstrating successful exploitation of exposed remote services. The activity was mapped to **MITRE ATT&CK Technique T1210**, which represents exploitation of vulnerable network services to gain initial access.

Following alert validation, analysts performed log review and network verification to confirm attack authenticity. No persistence artifacts, privilege escalation attempts beyond initial compromise, or lateral movement indicators were identified during the initial triage phase.

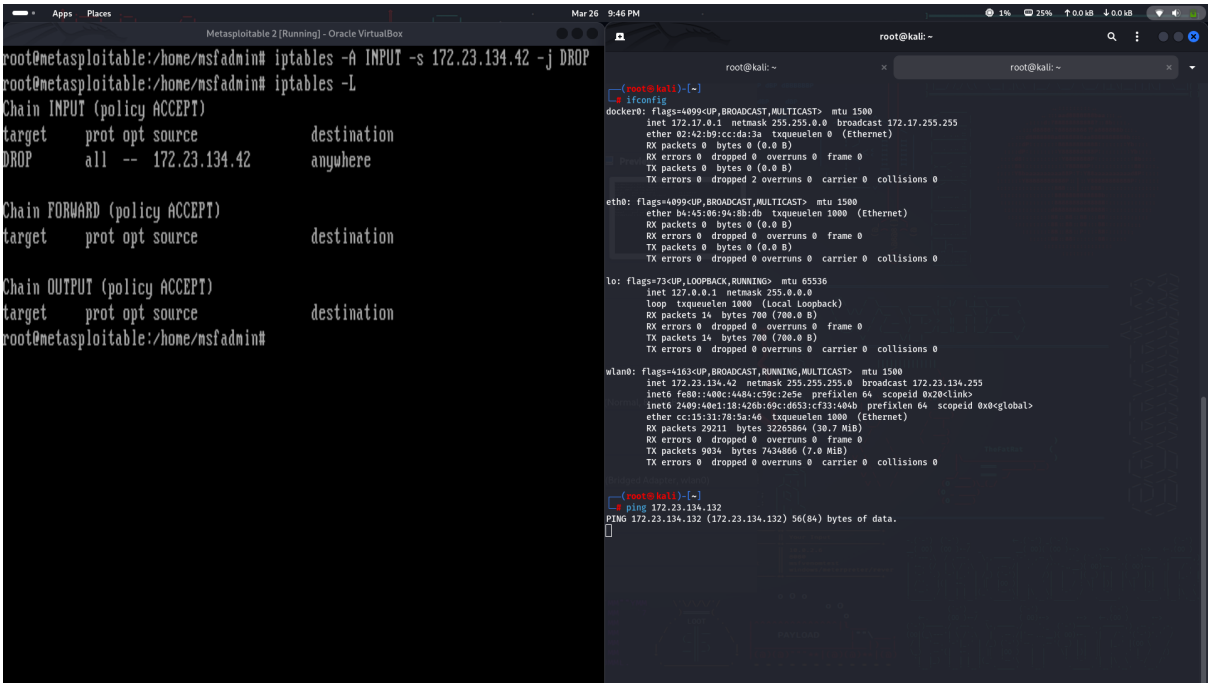
Containment Actions

Immediate containment measures were executed to prevent further attacker interaction with the compromised system.

Containment steps included:

- Blocking the attacker source IP using firewall rules
- Isolating the compromised Metasploitable2 host from attacker connectivity
- Verifying successful communication termination using network testing
- Preserving system state for potential forensic review
- Escalating the incident to Tier 2 analysts for deeper validation

These actions ensured rapid risk reduction and prevented additional compromise attempts.



Impact Assessment

The detected activity resulted in **unauthorized remote command execution access** on the affected system. However, no indicators of:

- persistence deployment
- privilege escalation chaining
- lateral movement activity
- data exfiltration attempts

were observed during initial investigation.

The incident was therefore classified as **High Severity – Confirmed Exploitation Attempt with Controlled Containment**.

Recommendations

To prevent recurrence of similar attacks, the following security improvements are recommended:

- Apply security patches to vulnerable Samba services
- Restrict exposure of SMB services to trusted internal networks only
- Implement network segmentation policies
- Enable stricter firewall filtering rules
- Strengthen intrusion detection rule coverage
- Integrate threat intelligence enrichment into SIEM alerts
- Conduct periodic vulnerability assessments across internal infrastructure

These actions will significantly reduce exposure to remote exploitation risks.

Conclusion

The SOC successfully detected and contained a simulated exploitation attempt targeting the Samba service on host **172.23.134.132**. The attack was identified through SIEM alert correlation and promptly mitigated through firewall-based containment actions.

The incident response workflow demonstrated effective coordination between detection, triage, containment, and escalation phases aligned with enterprise SOC operational practices.

The case has been escalated for additional forensic validation to confirm complete remediation and ensure no residual attacker presence remains within the monitored environment.